



Programa Certified AI-LLM Integration Engineer

Curso de Fundamentos de LLMs y APIs

www.bsginstitute.com

Andrés Felipe Rojas Parra

- Ingeniero electrónico con mas de 23 años de experiencia
- PGP Artificial Intelligence & Machine Learning at Texas University – Austin, TX
- Master en Inteligencia Artificial y Big Data – IEBSchool
- Estudiante de PGP en Cloud Computing at Texas University - Austin, TX
- Texas Executive Education Program – McCombs School of Business – Decision Science and AI Immersion Program
- Especialización en MLOps de la Universidad de Duke



arojaspa@outlook.com



@arojaspa



<https://www.linkedin.com/in/arojaspa/>



+573005906373



Sesión 3

Seguridad, Alta Disponibilidad y Diseño de Soluciones LLM

1 Triage Médico
Local (Ollama)

2 Auditoría Legal
Azure Foundry

3 Seguridad y
Alta Disponibilidad

4 Diseño y
Documentación

Agenda — Sesión 3

0

1

Triaje Médico — FastAPI + Ollama

~45 min

- Caso: Hospital LATAM con IA local
- Escala de Manchester + LLM
- JWT Bearer auth en la API
- Demo: paciente con IAM (infarto)

0

2

Auditoría Legal — Azure AI Foundry

~45 min

- Caso: Análisis de contratos comerciales
- GPT-4o detecta cláusulas de riesgo
- JSON mode para respuesta estructurada
- Demo: contrato con cláusulas abusivas

0

3

Seguridad y Alta Disponibilidad

~45 min

- WAF, JWT, RBAC, cifrado AES-256
- Replicación activo-pasivo
- Failover automático (RTO 60s)
- OWASP LLM Top 10

0

4

Diseño y Documentación

~45 min

- ADR — Architecture Decision Records
- Análisis de costos 5 proyectos
- Selección del Proyecto Final
- Template de documentación

T E M A 1

Triage Médico con IA — FastAPI + Ollama Local

Escala Manchester + LLM local + JWT Auth | Hospital público LATAM | Datos nunca salen del hospital

Triaje Médico — Arquitectura de 2 capas con JWT y privacidad total

Caso de Uso

Hospital HUV en Cali clasifica urgencias con IA. Datos NUNCA salen: cumple Resolución 1995 Colombia.

Escala Manchester

ROJO: Inmediato

NARANJA: < 10 min

AMARILLO: < 60 min

VERDE: < 120 min

AZUL: < 240 min

Seguridad JWT

Bearer token requerido.

Capa 1 Reglas Clinicas

Sin LLM — siempre disponible

Capa 2 Analisis LLM

Ollama — enriquece narrativa

Reconciliacion Final

Reglas = limite de seguridad

Código clave — triage_engine.py

```
def evaluate(self, req):
    # Capa 1: reglas clinicas
    rule_level, flags =
    quick_triage(req)

    # Capa 2: LLM local
    prompt = self._build_prompt(req)
    try:
        llm_resp =
        self._call_llm(prompt)
        parsed =
        self._parse_llm(llm_resp)
    except Exception:
        parsed = fallback(rule_level)

    # El nivel mas urgente gana
    final = reconcile(rule_level,
                      parsed["level"])

    return TriageResponse(
        triage_level=final,

        ai_assessment=parsed["assessment"]
    )
```

T E M A 2

Auditoría de Contratos Legales — Azure AI Foundry

GPT-4o detecta cláusulas de riesgo | JSON mode | RBAC por firma | Brazil South

Auditoría Legal — Azure AI Foundry con JSON mode estructurado

Por que Azure aqui?

GPT-4o tiene mejor comprension de lenguaje juridico complejo vs modelos pequenos.

JSON Mode

response_format: json_object garantiza JSON valido para parsear sin errores.

Cláusulas detectadas

Penalidades desproporcionadas

Terminacion unilateral

Responsabilidad limitada abusiva

PI cedida al proveedor

Confidencialidad excesiva

contract_auditor.py — Azure OpenAI SDK + JSON mode

```
self._client = AzureOpenAI(
    azure_endpoint=AZURE_ENDPOINT,
    api_key=AZURE_KEY,
    api_version="2024-12-01-preview"
)
response = self._client.chat.completions.create(
    model="gpt-4o",
    messages=[{"role": "system", "content": SYSTEM_PROMPT},
              {"role": "user", "content": prompt}],
    temperature=0.1,
    max_tokens=2000,
    response_format={"type": "json_object"} # <-- JSON garantizado
)
```

Respuesta JSON del modelo

```
{"overall_risk": "CRÍTICO", "recommendation": "NO FIRMAR",
 "risk_clauses": [
   {"category": "penalidades",
    "risk_level": "CRÍTICO",
    "original_text": "50% del valor por cada día de retraso",
    "issue": "Penalidad desproporcionada e ilegal según Ley 1480",
    "recommendation": "Negociar máximo 0.5% diario con tope del 10%",
    "legal_reference": "Art. 867 Código de Comercio Colombia"}
 ], "positive_aspects": ["Plazo de pago definido"]}
```


TEMA 3

Seguridad y Alta Disponibilidad en LLMs

OWASP LLM Top 10 | JWT + RBAC | WAF | Cifrado AES-256 | RTO 60s | RPO 15s

3.1 OWASP LLM Top 10 — Las 10 vulnerabilidades mas criticas en sistemas LLM

OWASP LLM Top 10 — Vulnerabilidades criticas en sistemas LLM

LLM01

•
CRITICO

Prompt Injection

Input malicioso manipula el comportamiento del modelo
Mitigacion: Sanitizar inputs, system prompt hardening, output valid...

LLM06

•
CRITICO

Sensitive Info Disclosure

El LLM revela datos sensibles del training o del contexto
Mitigacion: PII scrubbing, content filtering, DLP en outputs

LLM02

•
CRITICO

Insecure Output

El modelo genera codigo, comandos o datos peligrosos
Mitigacion: Escapar outputs, no ejecutar directamente, human-in-the...

LLM07

•
ALTO

Insecure Plugin Design

Plugins con acceso excesivo a sistemas externos
Mitigacion: Principle of least privilege, sandboxing, aprobacion hu...

LLM03

•
ALTO

Training Data Poisoning

Datos de entrenamiento comprometidos introducen sesgos
Mitigacion: Auditar datasets, curar fuentes, validacion de datos

LLM08

•
CRITICO

Excessive Agency

El LLM toma acciones autonomas de alto impacto sin supervision
Mitigacion: Limitar permisos, confirmacion humana, audit logs de ac...

LLM04

•
ALTO

Model Denial of Service

Inputs costosos saturan el modelo o agotan el presupuesto
Mitigacion: Rate limiting, max_tokens, timeouts, circuit breaker

LLM09

•
ALTO

Overreliance

Usuarios confian ciegamente en outputs del LLM sin verificar
Mitigacion: Disclaimers, humano en el loop, validacion de hechos cr...

LLM05

•
ALTO

Supply Chain Vuln.

Dependencias de modelos o librerias comprometidas
Mitigacion: SBOM, pin versiones, escaneo de deps, trusted registrie...

LLM10

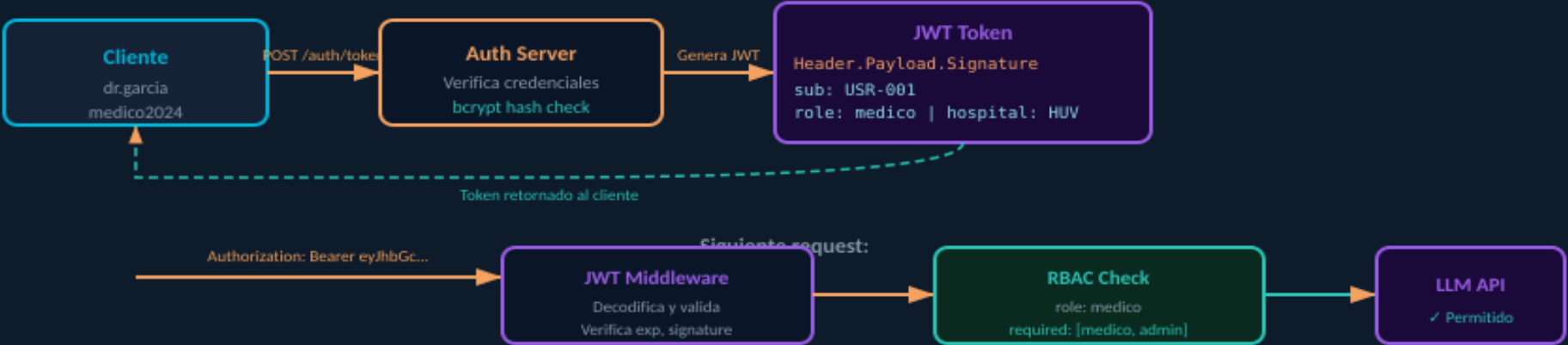
•
ALTO

Model Theft

Extraccion del modelo via APIs para replicar sin licencia
Mitigacion: Rate limits, fingerprinting, monitoreo de patrones de c...

3.2 Autenticacion y Autorizacion — JWT Bearer Tokens + RBAC por roles

Flujo JWT + RBAC — Autenticacion y Autorizacion para APIs LLM



Matriz de Permisos RBAC — Endpoints del Sistema

Endpoint	admin	medico	enfermero	auditor	readonly
POST /triage/evaluate	✓	✓	✓	✗	✗
GET /triage/history	✓	✓	✓	✓	✓
POST /contracts/audit	✓	✗	✗	✓	✗
GET /admin/users	✓	✗	✗	✗	✗
GET /health	✓	✓	✓	✓	✓

3.3 Cifrado de Datos — AES-256 en reposo y TLS 1.3 en transito

Cifrado de Datos — En reposo (AES-256) y en transito (TLS 1.3)

DATOS EN TRANSITO — TLS 1.3 (Transport Layer Security)



TLS 1.3 Handshake: ECDHE key exchange + AES-256-GCM + SHA-384

Forward Secrecy: cada sesion tiene clave unica — comprometer una sesion NO compromete las demas
En Python: `ssl.create_default_context()` | En FastAPI: `uvicorn --ssl-keyfile key.pem --ssl-certfile cert.pem`

DATOS EN REPOSO — AES-256 (Advanced Encryption Standard)



Gestion de Claves (Key Management)

Local: variable de entorno cifrada | Azure: Key Vault | AWS: KMS | GCP: Cloud KMS
NUNCA hardcodear claves en el codigo — usar variables de entorno o servicios de secrets

```
encryption.py
from cryptography
.fernet import Fernet
key = Fernet.generate_key()
f = Fernet(key)
token = f.encrypt(
data.encode())
plain = f.decrypt(
token).decode()
```

3.4 WAF, Rate Limiting y Headers de Seguridad HTTP

WAF, Rate Limiting y Proteccion contra ataques en APIs LLM

WAF — Web Application Firewall (Primera linea de defensa)

SQLi Blocking

Bloquea inyeccion SQL en prompts

XSS Filter

Elimina scripts en inputs

Prompt Injection

Detecta patrones de jailbreak

Bot Detection

Limita scrapers automatizados

DDoS Protection

Limita volumenes anormales de trafico

Rate Limiting — Token Bucket por cliente

Balde

token

token

token

vacio

vacio

3/5 tokens

rate_limiter.py (Token Bucket)

```
class RateLimiter:
def __init__(self, rpm=60):
self.capacity = rpm * 1.5
self.refill_rate = rpm/60
async def allow(self,
client_id):
self._refill()
if self.tokens >= 1:
self.tokens -= 1
return True # OK
return False # 429
```

Headers de Seguridad en Respuestas HTTP

X-RateLimit-Limit:	60	Max requests por minuto
X-RateLimit-Remaining:	57	Requests disponibles
X-RateLimit-Reset:	1735000000	Timestamp reset (Unix)
Retry-After:	3	Segundos hasta reintento
X-Content-Type-Options:	nosniff	Previene MIME sniffing
Strict-Transport-Security:	max-age=31536000	Obliga HTTPS 1 año
X-Frame-Options:	DENY	Previene clickjacking
Content-Security-Policy:	default-src 'self'	Previene XSS

3.5 Monitoreo, Logging Estructurado y Recuperacion ante Desastres

Monitoreo, Logging y Estrategias de Recuperacion ante Desastres

Stack de Observabilidad

Logs estructurados (JSON)

structlog + python-json-logger

Metricas de negocio

Prometheus + Grafana dashboard

Trazabilidad distribuida

OpenTelemetry + Jaeger

Alertas en tiempo real

Grafana Alerts + PagerDuty

Metricas Criticas para LLMs

Latencia P95 **menor 5s** 95% de requests bajo este umbral

Tokens/segundo **mayor 50** Throughput del modelo LLM

Error rate **menor 0.1%** Fallos sobre total de requests

Costo/1K requests **menor \$0.50** Control de presupuesto de tokens

Hallucination rate **menor 2%** Respuestas factulmete incorrectas

Token budget usado **menor 80%** Margen antes de quota exhaustion

Ejemplo: Log estructurado JSON

```
{
  "timestamp": "2024-12-15T14:32:01Z",
  "level": "INFO",
  "event": "TRIAGE_EVALUATED",
  "user": "dr.garcia",
  "role": "medico",
  "triage_level": "NARANJA",
  "processing_ms": 3842,
  "tokens": 287,
  "model": "llama3.2:3b",
  "hospital": "HUV"
}
```

Estrategia de Recuperacion ante Desastres

- Backup LLM config: Snapshot diario de prompts y configuracion del modelo
- DB Replication: PostgreSQL streaming replication — RPO menor 15 segundos
- Runbook automatizado: Playbooks de recuperacion ejecutados por el sistema
- Chaos Engineering: Simular fallos en staging antes de produccion

3.6 Alta Disponibilidad — Replicación, Failover y Recuperación ante Desastres

RTO y RPO

RTO (Recovery Time): max 60s de interrupcion.

RPO (Recovery Point): max 15s de datos perdidos.

Activo-Pasivo

Region primaria: Brazil South (ACTIVE)

Region DR: East US 2 (STANDBY)

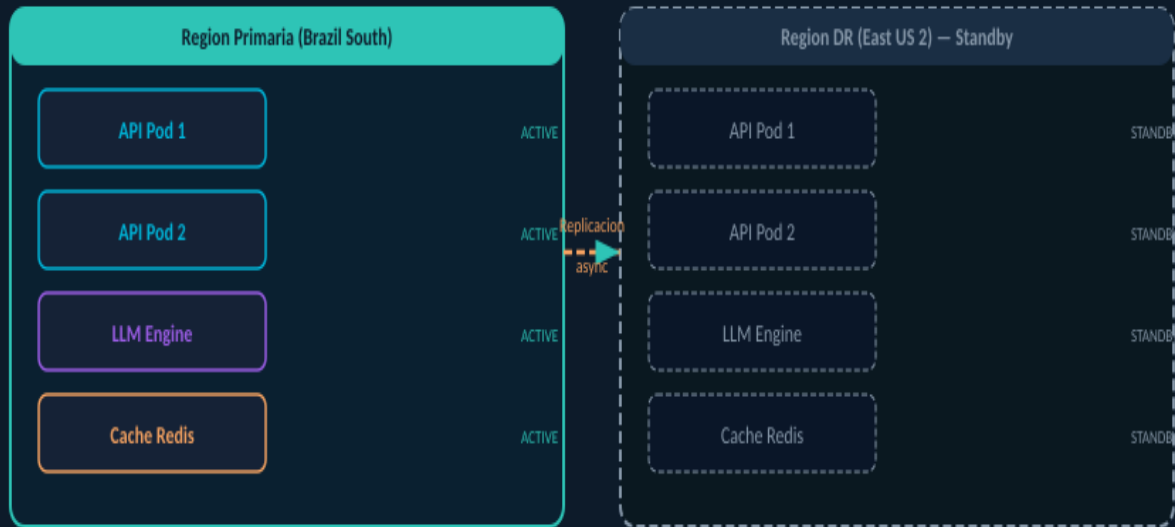
Replicacion async cada 15s.

Failover steps

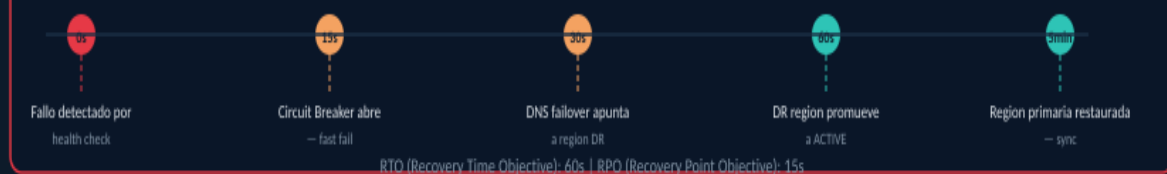
0s: health check detecta fallo

15s: Circuit Breaker abre

Alta Disponibilidad: Replicacion, Failover y Recuperacion ante Desastres



Estrategia de Failover Automatico



TEMA 4

Diseño, Documentación y Análisis de Costos

ADR | C4 Diagrams | TCO Analysis | Template de documentación empresarial

4.1 Estructura de Documentación y Análisis de Costos — Proyectos LLM

5 Secciones ADR

- 1. Alcance y contexto
- 2. Requerimientos RF/RNF
- 3. Arquitectura (C4)
- 4. Analisis de costos
- 5. Plan de implementacion

Costos tipicos LATAM

Local MVP: \$250/mes

Azure 10M tokens: \$800/mes

Dev senior LLM: \$3000-6000/mes

Estructura de Documentación — Proyecto LLM Empresarial



Architecture Decision Record (ADR) — Template

Título:	ADR-001: Selección del modelo LLM para producción
Estado:	ACEPTADO PROPUESTO DEPRECADO
Contexto:	Por que se toma esta decision y que problema resuelve
Decision:	Usaremos GPT-4o en Azure AI Foundry por SLA 99.9% y regiones LATAM
Consecuencias:	Costo \$X/mes Alternativa: Ollama local (\$0/token, menor calidad)

Analisis de Costos — Proyecto LLM LATAM (escenarios)



4.2 Diagrama C4 — Nivel 2: Contenedores del Sistema de Triage Medico

El modelo C4

4 niveles de zoom para arquitecturas de software.

Nivel 1: Contexto

El sistema y sus actores externos (usuarios, sistemas).

Nivel 2: Contenedores

Los procesos ejecutables: APIs, DBs, LLMs, caches.

Nivel 3: Componentes

Modulos internos de cada contenedor.

Diagrama C4 — Nivel 2: Contenedores (Sistema de Triage Medico)



4.3 Analisis de Costos Detallado — TCO y ROI de los 5 Proyectos LATAM

Componentes del TCO

Infraestructura: cloud, servidores.

LLM API: tokens por mes.

Desarrollo: horas de ingeniería.

Operacion: soporte, monitoreo.

ROI tipico LATAM

Automatizacion 40% tareas.

Ahorro: \$500-3000/mes.

Payback: 8-24 meses.

Formula clave

Analisis de Costos Detallado — 5 Proyectos LATAM

Proyecto	Infra/mes	LLM API/mes	Dev inicial	Total 6m	ROI est.
FinTech Credit	\$350	\$200	\$8,000	\$13,300	18 meses
MediAssist	\$500	\$0 (local)	\$12,000	\$15,000	24 meses
LegalScan Pro	\$300	\$600	\$10,000	\$16,000	12 meses
EduBot	\$150	\$100	\$6,000	\$7,500	8 meses
RetailGenius	\$200	\$150	\$7,000	\$9,100	10 meses

Desglose TCO — FinTech Credit AI (12 meses)

Infraestructura (AWS/Azure)	\$4,200	Desarrollo e integracion	\$8,000
LLM API (tokens OpenAI)	\$2,400	Monitoreo y seguridad	\$1,400

Calculadora ROI — Formula

Ahorro mensual = Costo proceso manual - Costo LLM
ROI (%) = (Ahorro neto / Inversion total) x 100
Payback = Inversion / Ahorro mensual (meses)
Ejemplo FinTech: \$15K inversion / \$800/mes ahorro = 19 meses

4.4 Template de Documentacion — ADR + Checklist de Entrega del Proyecto

Template de Documentacion — Proyecto LLM Enterprise

1. ALCANCE Y CONTEXTO

[Documento de Arquitectura LLM]

1.1 Descripción del problema

Que problema de negocio resuelve el LLM?

1.2 Stakeholders

Quien usa el sistema y quien lo aprueba?

1.3 Alcance del MVP

Que entra y que NO entra en v1.0?

1.4 KPIs de éxito

Como medimos si el proyecto funciona?

2. REQUERIMIENTOS

2.1 Funcionales (RF)

API endpoints, casos de uso, flows

2.2 No funcionales (RNF)

Performance, disponibilidad, seguridad

2.3 Restricciones tecnicas

Budget, stack obligatorio, compliance

3. ARQUITECTURA

3.1 Diagrama C4 nivel 2

Contenedores e interacciones

3.2 ADR - Decisiones clave

Por que elegimos este LLM/cloud?

ARCHITECTURE DECISION
RECORD (ADR)

ADR-001

Titulo: Seleccion del modelo LLM

Estado:

ACEPTADO (fecha: 2024-12-15)

Contexto:

Necesitamos un LLM para analizar contratos legales c...

Opciones:

A) GPT-4o Azure | B) Llama 3.1:70B | C) Claude 3.5 S...

Decision:

Opcion A — GPT-4o en Azure AI Foundry

Por que:

Mejor comprension juridica LATAM, SLA 99.9%, soporte...

Contra:

Opcion B: menor costo pero peor calidad. Opcion C: s...

Consecuencias:

Costo: \$600/mes. Vendor lock-in Azure. Usar LangChai...

Revisable en:

6 meses o si el costo supera \$1,200/mes

CHECKLIST DE ENTREGA

REPOSITORIO

☐ README.md con instrucciones

☐ requirements.txt y Makefile

☐ Estructura de carpetas correcta

☐ .env.example sin secretos

CODIGO

☐ Min 3 endpoints funcionales

☐ Autenticacion implementada

☐ Tests unitarios basicos

☐ Comentarios en funciones clave

DOCUMENTACION

☐ ADR completado

☐ Diagrama de arquitectura

☐ Analisis de costos inicial

☐ Instrucciones de despliegue

4.5 Requerimientos — Funcionales (RF) y No Funcionales (RNF) para LLMs

Requerimientos Funcionales (RF)

RF-001

El sistema debe clasificar pacientes segun escala Manchester (5 niveles)

RF-002

La API debe retornar respuesta en < 10 segundos para nivel ROJO

RF-003

El sistema debe registrar cada evaluacion en log de auditoria

RF-004

Los endpoints deben requerir autenticacion JWT valida

RF-005

El sistema debe soportar 50 solicitudes concurrentes

RF-006

La API debe proveer endpoint /health para monitoreo K8s

Requerimientos No Funcionales (RNF)

RNF-001

Disponibilidad: SLA 99.5% (max 3.6h downtime/mes)

RNF-002

Performance: P95 < 5s, P99 < 10s para /triage/evaluate

RNF-003

Seguridad: cifrado AES-256 datos en reposo, TLS 1.3 en transito

RNF-004

Privacidad: datos clinicos NO salen de la infraestructura local

RNF-005

Escalabilidad: HPA de 2 a 10 pods automaticamente

RNF-006

Cumplimiento: Resolucion 1995/1999 Colombia, HIPAA principles

4.6 Proyecto Final — Selección Hoy en Sesión 3 (presentar en Sesión 4)

Cada equipo (max 2 personas) elige UN proyecto. La seleccion es definitiva. Completar el formulario antes de salir de la sesion.

1. FinTech Credit AI

Financiero | ★★ ★ | FastAPI+Ollama+Redis

2. MediAssist LATAM

Salud | ★★ ★★ ★ | FastAPI+Ollama+AES

3. LegalScan Pro

Legal | ★★ ★★ ★ | FastAPI+Azure GPT-4o

4. EduBot Adaptativo

Educacion | ★★ ★ | FastAPI+Ollama+Redis

5. RetailGenius

Retail/eComm | ★★ ★ | FastAPI+Ollama o Azure

Formulario de Seleccion

Nombre(s): _____

Proyecto #: ____ Nombre: _____

Justificacion (1 oracion): _____

Stack preferido: _____

Fecha entrega: Antes Sesion 4

4.7 Resumen y Tareas

Aprendimos Hoy

- Triaje medico con escala Manchester + LLM local (2 capas de seguridad clinica)
- JWT Bearer auth + RBAC para endpoints medicos y legales
- OWASP LLM Top 10: prompt injection, sensitive disclosure, overreliance
- Failover activo-pasivo: RTO 60s, RPO 15s entre regiones
- ADR: estructura de documentacion para proyectos LLM empresariales

Tarea para Sesión 4

- 1. Seleccionar proyecto final y entregar formulario firmado
- 2. Instalar y probar make run-medical — demo con paciente IAM
- 3. Leer el ADR template en `project_catalog/README.md`
- 4. Preparar propuesta inicial: problema, stack, arquitectura basica
- 5. Estimar costos de tu proyecto (usar plantilla de Tema 4)